

Aula 5

Segurança da Informação

Prof. Patrick Landal Athayde

1

Fundamentos e modelos de controle de acesso

2

Segurança no acesso digital

- **Segurança no acesso é central na proteção da informação**
- **Autenticação, autorização e controle de acesso como pilares estratégicos**

3

Segurança no acesso digital

- **Funções:**
 - **Autenticação** → confirma identidade
 - **Autorização** → define permissões
 - **Controle de acesso** → regula uso conforme regras

4

Autenticação

- **Métodos principais:**
 - O que o usuário sabe: senhas complexas, PINs
 - O que o usuário possui: *tokens*, *smart cards*, cartões magnéticos
 - O que o usuário é: biometria (digital, facial, íris)
- **Objetivo:** garantir singularidade e segurança do acesso

5

Autorização

- **Ocorre após a autenticação**
- **Define o que o usuário pode fazer e quais recursos acessar**
- **Baseada em funções, perfis ou atributos**
- **Exemplo: Fontes (2015) – autenticação confirma quem é, autorização define o que pode fazer**

6

Auditoria

- Registro contínuo de atividades de usuários
- Coleta dados como:
 - Tempo de conexão
 - Volume de dados transmitidos
 - Endereço IP
 - URIs acessados
 - Serviços utilizados

7

Auditoria

- **Identificar comportamentos suspeitos**
- **Verificar conformidade com políticas**
- **Apoiar cobrança e faturamento de serviços**

8

Modelos clásicos: DAC, MAC, RBAC, ABAC

9

Modelos de controle de acesso: visão geral

- **Função:** definir políticas que regulam quem pode acessar quais recursos e em quais condições
- **Objetivos:**
 - **Garantir autorização apropriada**
 - **Preservar confidencialidade, integridade e disponibilidade**
 - **Atender requisitos normativos e organizacionais**

10

Modelo DAC (Discretionary Access Control)

- **Definição:** controle de acesso determinado pelo proprietário do recurso
- **Permissões:** leitura, escrita e execução concedidas ou revogadas pelo proprietário
- **Vantagens:**
 - Flexível e fácil de implementar

11

Modelo DAC (Discretionary Access Control)

- ❑ **Desvantagens:**
 - **Suscetível a erros humanos e escalonamento de privilégios**
 - **Menos adequado para ambientes de alta segurança**
- ❑ **Aplicação: usado em sistemas operacionais, geralmente combinado com outros modelos**

12

Modelo MAC (Mandatory Access Control)

- **Definição:** controle de acesso baseado em regras obrigatórias definidas pelo sistema
- **Mecanismo:** etiquetas de segurança classificam usuários e objetos

13

Modelo MAC (Mandatory Access Control)

- **Princípios:**
 - Usuário recebe autorização de segurança (*clearance*)
 - Objetos têm classificação de segurança (sensibilidade)

14

Modelo MAC (Mandatory Access Control)

- **Fluxo de informação:**
 - Leitura permitida de nível superior
 - Escrita restrita para evitar vazamentos
- **Aplicação:** ambientes de alta segurança e com dados classificados

15

Modelo RBAC (Role-Based Access Control)

- **Definição:** permissões atribuídas a papéis (*roles*), e não a indivíduos diretamente
- **Vantagens:**
 - Gerenciamento eficiente de permissões
 - Segurança alinhada às funções organizacionais
 - Alta escalabilidade para ambientes complexos

16

Modelo RBAC (Role-Based Access Control)

- **Funcionalidades adicionais:**
 - Hierarquia de papéis
 - Separação de deveres
 - Restrições específicas
- **Aplicação:** amplamente usado em empresas e instituições

17

Modelo ABAC (Attribute-Based Access Control)

- **Definição:** controle de acesso baseado em atributos do usuário, recurso, ação e ambiente
- **Vantagens:**
 - Dinâmico, granular e adaptável
 - Permite políticas complexas e sofisticadas

18

Modelo ABAC (Attribute-Based Access Control)

- Desvantagens:
 - Alta complexidade de implementação e manutenção
- Mecanismo:
 - Ponto de decisão de política (PDP)
 - Ponto de aplicação de política (PEP)

19

Gestão de identidades e governança de acesso (IAM)

20

IAM (Identity and Access Management)

- Importância
 - Evita acessos indevidos
 - Essencial em ambientes com:
 - Alta rotatividade de pessoal
 - Múltiplos sistemas e plataformas
 - Necessidade de conformidade regulatória

21

Ciclo de vida da identidade digital (IAM)

- Etapas do ciclo
- Criação (provisionamento)
 - Estabelece identidade digital única (nome, função, credenciais, perfis de acesso)
 - Direitos iniciais atribuídos conforme função ou contexto
 - Automatização comum em ambientes integrados a RH e CRMs

22

Ciclo de vida da identidade digital (IAM)

- Modificação
 - Ajustes conforme mudanças funcionais ou administrativas
 - Aplicação do princípio do menor privilégio
 - Rastreabilidade e controle de alterações

23

Ciclo de vida da identidade digital (IAM)

- Revogação (desprovisionamento)
 - Exclusão controlada de acessos ao fim da necessidade
 - Evita contas órfãs e riscos de exploração
 - Automação para reduzir riscos internos

24

Ferramentas e soluções IAM

- Principais plataformas
 - Okta
 - Baseada em nuvem, especializada em MFA e SSO
 - Diretório universal, gestão de ciclo de vida, gateway de acesso e controle de APIs

- 25

Ferramentas e soluções IAM

- **Azure Active Directory (Azure AD)**
 - **Integração nativa com Office 365 e Azure**
 - **Sincronização de senhas, MFA, acesso local e na nuvem, controle por grupos**

- 26

Ferramentas e soluções IAM

- **ForgeRock**
 - **Plataforma modular: autenticação, autorização, governança e gateways de identidade**
 - **Alta flexibilidade e escalabilidade, alinhada ao conceito de "Identity Fabric"**

- 27

Controle de Acesso RBAC e ABAC

Comparativo entre duas estratégias

Característica	RBAC	ABAC
Modelo de acesso	Baseado em funções	Baseado em atributos
Granularidade	Menos granular	Mais granular
Flexibilidade	Menos flexível	Mais flexível
Complexidade	Mais simples	Mais complexo
Desempenho	Geralmente mais rápido	Pode ser mais lento

Fonte: Athayde, 2025.

28

Fonte: Athayde, 2025.

Segurança em ambientes modernos (Cloud, Mobile e DevOps)

Segurança de acessos na nuvem e ambientes ágeis

- **Cenário atual**
 - Migração de sistemas para nuvem
 - Uso massivo de dispositivos móveis
 - Adoção de práticas DevOps
 - Dissolução do perímetro tradicional de segurança

- 29

Segurança de acessos na nuvem e ambientes ágeis

- Práticas e estratégias
 - Controles de acesso nos principais provedores de nuvem:
 - AWS, Azure, GCP
 - Proteção de ambientes de integração e entrega contínua (CI/CD)
 - Uso de autenticação federada entre múltiplos domínios

31

Identidade como novo perímetro (*zero trust architecture*)

- Mudança de paradigma: nuvem, mobilidade e DevOps dissolvem o perímetro tradicional
- Identidade como núcleo da segurança (Garey, 2024)
- Princípio *zero trust*: "Nunca confiar, sempre verificar" (NIST, 2020)
- Confiança não é implícita: aplica-se a usuários, dispositivos e aplicações, dentro ou fora da rede

32

Identidade como novo perímetro (*zero trust architecture*)

- Controles centrais:
 - Autenticação multifator (MFA)
 - Políticas adaptativas
 - Monitoramento comportamental
- Substituição dos "muros digitais" por resiliência dinâmica e sensível ao contexto

33

Controle de acesso em nuvem (AWS IAM, Azure RBAC)

- Princípio do menor privilégio e segregação de funções (Microsoft, 2025)
- AWS Identity and Access Management (IAM):
 - Políticas em JSON, perfis, grupos e funções
 - Gerenciamento de credenciais temporárias
 - Integração com provedores externos de identidade

34

Controle de acesso em nuvem (AWS IAM, Azure RBAC)

- Azure Role-Based Access Control (RBAC):
 - Papéis predefinidos ou personalizados
 - Escopos: assinatura, grupos de recursos, recursos individuais
 - Hierarquias de herança para controle e auditoria

35

Segurança em aplicações móveis, APIs e CI/CD

- Aplicações móveis:
 - Criptografia forte
 - Controles *anti-tampering*
 - Gestão rigorosa de segredos
 - Atualização rápida de vulnerabilidades

36

Segurança em aplicações móveis, APIs e CI/CD

- APIs:
 - Autenticação robusta (OAuth, OpenID Connect)
 - Análise comportamental *com machine learning*
 - Versionamento seguro e inspeção contínua

37

Segurança em aplicações móveis, APIs e CI/CD

- CI/CD (integração e entrega contínua):
 - Princípio *shift-left*: segurança desde o início
 - Análise estática/dinâmica de código
 - Validação de segredos e dependências
 - Automação de *compliance*

38

Autenticação federada e ambientes híbridos

- Ambientes híbridos: *on-premises* + *cloud*
- Protocolos de federação: SAML, OAuth2, OpenID Connect
- Single Sign-On (SSO) entre múltiplos domínios
- Integração de diretórios locais (ex.: Active Directory) com identidades em nuvem (Azure AD, Google Cloud Identity)

39

Tendências e normas

40

Alinhamento com normas, leis e tendências emergentes

- Normas e regulamentações
 - ISO/IEC 27001 e 27002 – padrões internacionais para gestão de segurança da informação
 - Guias do NIST – práticas recomendadas para autenticação, autorização e controle de acesso

41

Alinhamento com normas, leis e tendências emergentes

- LGPD (Brasil) – proteção de dados pessoais e direitos dos titulares
- GDPR (Europa) – regulamentação de privacidade e segurança de dados

42

Alinhamento com normas, leis e tendências emergentes

- **Tendências emergentes**
 - **Autenticação adaptativa baseada em risco – ajustes dinâmicos do nível de autenticação conforme contexto e ameaça**

43

Autenticação adaptativa e inteligência artificial

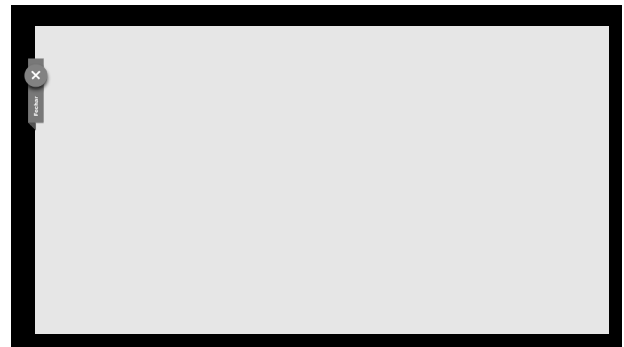
- **Autenticação adaptativa baseada em risco e IA**
- **Fatores contextuais: localização, dispositivo, comportamento**
- ***Machine learning* para detecção de anomalias**
- **Balanceamento entre usabilidade e segurança via MFA e biometria**

44

***Blockchain* e identidade descentralizada**

- **Identidade digital distribuída e não centralizada**
- **Controle do usuário sobre suas credenciais**
- **Redução de riscos e aumento da privacidade**
- **Aplicações em ambientes híbridos e federados: interoperabilidade e auditabilidade**

45



46